

1/40



File No.: EXP202315109

RESOLUTION OF TERMINATION OF THE PROCEDURE BY RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On November 19, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L. (hereinafter, HO), through the agreement that is transcribed:

<<

File No.: EXP202315109

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On August 28, 2023, a complaint was filed with the Spanish Agency for Data Protection regarding a possible infringement attributable to DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L. with NIF B39843487 (hereinafter, HO).

The complainant reports the existence of a security breach that affected HO and resulted in the exposure of personal data of thousands of customers, including himself.

Along with the written complaint, the complainant provides a link to a website where the leaked data is listed.

This AEPD proceeded to download and document the file with the leaked data from the URL provided by the complainant.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on 10/27/2023, this complaint was forwarded to HO, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/40

The complained party responded to the transfer and request for information on 11/24/2023; however, from the information provided, a possible violation of data protection regulations can be inferred.

THIRD: On November 28, 2023, in accordance with Article 65 of the LOPDGDD, the complaint was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

As a result of the actions taken, the following points have been noted:

.-1-. Regarding the evidence provided and the chronology of the reported facts.

The complainant provides the link to the publication of the breach in a forum from which access can be gained to download the data.

The publication in the forum ***FORO.1, dated June 24, 2023, refers to a publication on ***WEBSITE dated November 28, 2022, indicating that in January 2022 the online clothing store ***STORE.1 suffered a personal data breach affecting (...) customers.

Once the file [Data_***FORO.1] was downloaded, the data contained in the Excel file of the downloaded archive was analyzed. The data contained in the Excel includes:

- Name and surname.
- Postal and email address.
- User data and password for their account (encrypted).
- Billing data: Name, surname, postal address, and phone number.

It is verified that the Excel file contains a total of (...) entries, of which two rows contain the information of the complainant, specifically rows: 8,497 and 17,571.

It is also confirmed that the latest registration dates of users correspond to January 16, 2022, so this date could be deduced as the date of the personal data breach.

Both the capture of the publication and the downloaded file are included in the file in SIGRID, as Annex Documents to the entry of the complainant.

Therefore, the following chronological facts are concluded:

.- On January 2022 (probably on the 16th), the data from the page ***STORE.1 was leaked.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/40

.- On November 28, 2022, a personal data breach and the link to the file are published on the forum ***WEBSITE.

.- On June 24, 2023, a personal data breach and the link to the file are published on the forum ***FORUM.1.

.- On August 28, 2023, the claimant submits their complaint to the Spanish Agency for Data Protection.

.- On October 27, 2023, the AEPD forwards the complaint to the respondent.

.- On November 21, 2023, the respondent notifies the security breach.

.- On November 24, 2023, they send their written response to this Agency regarding the forwarded complaint.

.- On December 19, 2023, the respondent informs the affected individuals by sending an email through the sending platform ***COMPANY.1.

.-2.- Regarding the forwarding of the complaint

On October 27, 2023, the complaint is forwarded to the respondent, who sends their written response to this Agency with a registration date of November 24, 2023, which includes the Record of processing activities. They also attach three documents that encompass the following documentation:

- Document 1: "Report from an internal IT professional of the investigated company indicating what he believes may have happened."

- Document 2: Measures applied in the creation of the initial website.

- Document 3: Complaint filed with the Civil Guard.

- Document 4: Certificate (issued by ***CONSULTANT.1) of the current security measures implemented in the eCommerce and on the server and of the additional security measures to be implemented.

- Document 5: Draft communication to clients regarding the events that occurred. They inform (on 11/24/2023) that they intend to send it "as soon as possible."

The written response to the forwarded complaint provided by HO includes, among other statements:

"2.- The administrative person in our company responsible for receiving communications that come to us through the communications mailbox reviewed the deadline for responding and, seeing that it was 30 days, archived it to analyze it when 'there was less time until the expiration of the deadline.' This has caused, as our lawyer has explained to us, that we have completely failed to meet the deadline that the law grants for making the appropriate and necessary notification of a Security Breach to the Agency and for us to start working on this matter.

[...]

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5.- Considering the dates provided in the claim, we verify that approximately around those dates a migration of data from the old website to the new website, created by the IT company, took place. Therefore, we deduce, and we are currently in the process of expanding our verification, that the loss of data may have occurred on the dates indicated by the claimant and the Agency itself. Unfortunately, we learned about this through the Agency's letter. We attach as Document 1 a report from an internal IT professional of our company who, upon investigation, indicates what he believes may have happened. This report is being sent to all those collaborating with the company so that we can advance in the investigations.

6.- We have accessed the links provided to us through your request and, unfortunately for us, they contain data from our clients of our online business. It is evident that in the migration carried out by the company managing our website, adequate measures were not taken to perform it more securely. In the data we have, we had implemented security measures to prevent access or data loss by the IT company managing our e-commerce, and we never had any problems. We attach as Document 2 the measures that were applied in the creation of the initial website format.

[...]

8.- As I mentioned at some previous point, this is a very serious issue for us that this has occurred. At the time, and advised by the company that set up the online store, measures were implemented, which we have attached as Document 2, specifically to prevent any data loss. Last Monday, we proceeded to hire the services of a professional IT expert, whose name is A.A.A., to try to ascertain exactly what may have happened in this case, and in an initial report, he outlines a series of facts that may have occurred. Thus, both this cybersecurity expert and the company managing the website (from which we are awaiting a definitive report) agree that security may have been insufficient during the data transfer.

9.- We have proceeded to download the file containing the data, noting that it includes contact information and user and password data for the private section of our website. There are no payment method data or bank card information. And as indicated by the claimant, there may be some (...) user and client data. The most sensitive data that may exist, though not in all cases, is the mobile phone number.

10.- The consequences for the affected individuals, we understand from the company, may arise if there is improper use of the data contained in that file by any person to contact them. In any case, we are unaware of what may happen when there is a data file of individuals on a page like the one indicated to us. The IT expert must provide us with a report on possible measures to be taken regarding the existing file on the page indicated to us in order to attempt to eliminate it.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/40

11.- On the part of the company, and after becoming aware of this leak, a report was made to the Civil Guard regarding these events, responding to the questions posed by the agent and, in addition, we provided an attached document to the report where we explained what happened in a somewhat more detailed manner concerning the information we had at that time. [...]

13.- Apart from the loss of data, we have seen that the protocols we have implemented in the company have failed, so we have tried in these days to see what can be improved regarding our way of acting concerning incident communications, legal notifications, exercise of rights, and customer calls with incidents in purchases. [...]"

It is noteworthy that HO acknowledges having "totally failed to meet the deadline that the law grants for making the appropriate and necessary notification of a Security Breach to the Agency" (Point 2), that "the appropriate measures were not taken to carry out the (migration of the website) in a more secure manner" (Point 6), and that "the protocols we have implemented in the company have failed" (Point

13).

.-2.1-. Regarding the explanation of the breach provided in the response to the transfer.

The responding party provides the explanation given by the IT technician of their company, based on a backup copy used during the migration of the website.

“According to the notification received, the database leak occurred in November 2022.

At that time, we were working with a company (**CONSULTORA.1) that was going to create a new website for us. Specifically, they put it online for initial testing on November 3.

With the change of the website, we need to maintain the order and user history to keep track of the sales made up to that moment.

In this regard, we believe that the team of IT professionals and/or programmers performing this migration of order and user history installs a plug-in on the website that exports said data from the old website, to later be imported into the new one.

We reached this conclusion because the IT team of **CONSULTORA.1 informed us that they found in a backup copy from that time the file in a folder of a plug-in used for the purposes we have mentioned. They also told us that this file is no longer available.

These files are exported to a folder generated by the plug-in in the backend of the website. In any case, it is not visible or accessible to web users.

During the time the file is in that folder for the migration process, a person with advanced IT knowledge, a "hacker," has been able to bypass the security measures of the website and the hosting, entering those hidden folders and making a copy of the file.

We believe that the person who downloaded the file took advantage of this web migration time to carry out the attack and steal the file.”

.-2.2-. Regarding security measures.

The responding party submits the document “Measures that were applied in the creation of the initial website,” which is an extract of the information provided on the page of (...)

The page has been updated in April 2024, and the inspector incorporates into the file the capture from waybackmachine:

(...)

It also provides the document “Certificate issued by **CONSULTORA.1 of the current security measures implemented in the eCommerce and in the server and of the extra security measures to be implemented.” This document specifies:

“Current security measures implemented in the eCommerce and in the server:

- Installation of the security layer on Amazon AWS (AWS server) where the eCommerce is hosted, which provides services that help protect data, accounts, and workloads from unauthorized access. The AWS data protection services contracted provide encryption capabilities, key management, and discovery of confidential data to protect data, processing, and workloads.
- Wordfence security plugin installed on the eCommerce that includes a web application firewall (WAF) and a malware scanner. It has other security measures such as access security (2FA, CAPTCHA login page, limiting access attempts), Live Traffic, and advanced rule-based blocking.
- Regularly updating WordPress plugins (weekly) which is a primary security measure for the eCommerce. Plugin updates may include new features or performance and security improvements.

Extra security measures to be implemented:

Implementing the AWS Trusted Advisor solution in the AWS cloud infrastructure, which is an online tool that acts as a cloud expert and can be customized to help configure resources according to best practices. Trusted Advisor inspects your AWS environment to eliminate security deficiencies and looks for...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/40

opportunities to save money, improve system performance, and increase reliability.

Use hash techniques and encryption to store passwords securely. Strong password policies can also

be implemented for customers.

Conduct regular security tests to identify and address potential vulnerabilities in eCommerce. Use security scanning tools and conduct audits systematically.

Implement two-factor authentication (2FA), which adds an additional layer of security. It requires customers to provide a second form of authentication, such as a code sent to their phone, in addition to their password, to access their account.

.-2.3-. Regarding the Record of Processing Activities

The respondent provides in its written response to the transfer of the complaint information contained in the Record of Processing Activities.

.-3-. Regarding the notification of the security breach

As explained by the respondent in its written response to the transfer of the complaint, the entity became aware of the personal data breach following a request for information from the AEPD.

Notified of the transfer of the complaint to the respondent on October 31, 2023, HO notified the AEPD of the security breach on November 21, 2023.

The relevant data communicated in the notification of the security breach to this Agency are as follows:

- Approximate number of individuals whose personal data is collected, stored, or otherwise processed; referring exclusively to the processing related to the personal data breach: (...)
- The processing related to the breach includes data of individuals solely in Spain, at the national level.
- As a consequence of the incident, confidentiality has been affected.
- The data is not securely encrypted, anonymized, or protected in such a way that it is unintelligible to those who may have accessed it or that individuals cannot be identified.
- Description of what occurred.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/40

“We believe that, during the migration in 2022 from one website to the new website, a file was generated that the company managing the website subsequently did not destroy. The data controller currently has no commercial relationship with that company; in fact, there have been various legal proceedings related to services provided by it.”

- The breach will be communicated to the affected individuals no later than: 31/12/2023.
- The data controller has not designated a DPO.
- No data processor is involved in the personal data breach.
- The security measures implemented in the organization before the breach occurred: Data protection and security policies, Training in data protection and information security at the appropriate level, Periodic audits, Logical access control, Backup.

The breach could have been avoided by adopting some additional security measure.

The incident occurred due to some failure, deficiency, or non-compliance with implemented security measures.

- New security measures and those that have been updated: Data protection and security policies, Training in data protection and information security at the appropriate level, Computer systems are kept updated, Incident log, Periodic audits, Logical access control, Backup.

.-4-. Regarding the information provided in response to the information request during the preliminary investigation proceedings

On April 10, 2024, an information request is made to the respondent asking for, among other points, a copy of all reports provided by the expert IT forensic analyst regarding the security breach and all reports provided by the company managing the website, in addition to a detailed specification of the causes that made the breach possible, considering its date in January 2022.

The respondent responds to this information request with a registration date of April 24, 2024, providing the following documentation attached to its written response:

- Copy of the email sent to clients (19/12/2023).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/40

- Copy of all contracts with ***CONSULTORA.1 and email communications regarding the breach or AMS for Ecommerce ***TIENDA.1. Date 04/24/23.
- AWS Cloud Hosting - AWS Hosting Service / Support and maintenance. Date 03/03/22.
- Cloud Infrastructure and Improvements – Project. Date 03/03/22.
- Progress Report December 2021 – January 2022. Date 01/31/22.
- Communications - Security audit conducted by ***EMPRESA.2, which includes the expert report from the National Association of Appraisers and Judicial Computer Experts - ANTPJI.
- .4.1-. Regarding the communication made to the affected parties, HO states that they informed the affected individuals by sending an email to each of them through the ***EMPRESA.1 sending platform. They provide a copy of the email sent to clients by ***EMPRESA.1, dated 12/19/2023.
- .4.2-. Regarding the maintenance of the Information Systems affected by the breach, carried out by third-party companies

The responding party indicates in their written response to the request that “Given the insecurity that the previous company that managed our business until 2021 seemed to demonstrate at the time, we decided to consult the entity ***CONSULTORA.1.

In the case of the company that maintains the website, this company began a project in DECEMBER 2021, which was when the first contract was signed, and has continued to the PRESENT.

***CONSULTORA.1 has been working and helping us to comply with everything that our website entails.” They provide a copy of the following contracts with ***CONSULTORA.1, as previously mentioned:

- AMS for Ecommerce ***TIENDA.1. Date 04/24/23.
- AWS Cloud Hosting - AWS Hosting Service / Support and maintenance. Date 03/03/22.
- Cloud Infrastructure and Improvements – Project. Date 03/03/22.
- Progress Report December 2021 – January 2022. Date 01/31/22.

The importance of this last report lies in the fact that the reported security breach occurred precisely during and after the time frame (December 2021 - January 2022) to which this report from ***CONSULTORA.1 refers.

The report consists of a list of Completed Tasks, Planned Tasks, and Future Observations, namely:
Completed Tasks

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/40

- Production launch of the new website for ***TIENDA.1.
- Developments made (...).
- Update of catalog, users, and orders from the previous production website.
- Integration of developments.
- Infrastructure diagnostics and resource increase.
- Effort in hours spent: 108 hours.
- Correction of operational reports.

Planned Tasks

- Presentation of cloud infrastructure offer and improvements to the website for February 2022, under the responsibility of ***CONSULTORA.1.

Observations

- Sending of monthly reports detailing progress on the project.
- Next step: move the website to auto-scaling cloud infrastructure.

- ***CONSULTORA.1 commits to preparing an offer in this regard, to present to the client in February 2022, with concrete proposals for improvements in the operation and use of the website. Requested the contract of data processor or sub-processor with third-party companies, HO states that ***CONSULTORA.1 “does not process customer data in their work on the website. Therefore, they have not been considered as data processors, nor as sub-processors.”

.-4.3-. Regarding communications with ***CONSULTORA.1

The responding party provides the email communications with the company ***CONSULTORA.1 regarding the breach. The most relevant content is reproduced in the email dated November 8, 2023: “We have conducted a thorough analysis pulling from backups and have seen in an old copy that there was a file with all the data in the uploads folder. The folder was named (...), and looking online it seems to be a plugin that exports users from the database.

The truth is that we have no record of that plugin as it is not installed nor have we seen it in the backups.

We have also seen that as of today the file no longer exists, so we understand that the risk is mitigated.”

At HO's request, ***CONSULTORA.1 sent a detailed report on the current security measures of the website and server and possible additional security measures that could be implemented to prevent information theft from occurring again, sent to this Agency in response to the transfer of the complaint, Certificate issued by ***CONSULTORA.1 of the current security measures implemented in the eCommerce and server and the additional security measures to be implemented.

This document specifies the security measures that have been previously detailed in section 2.2 of the report on prior investigative actions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/40

.-4.4-. Regarding the personal data involved in the breach

The responding party indicates in its written response that the types of affected data are as follows: “ID, customer id, user login, user pass (encrypted (...)), user nice name, user email, user url, user registered, display name, first name, last name, user status, roles, nickname, description, rich editing, syntax highlighting, admin color, use ssl, show admin bar front locale, wp user level, dismissed wp pointers show welcome panel session token, last update, billing first name, billing last name, billing company, billing email, billing phone, billing address 1, billing address 2, billing postcode, billing city, billing state, billing country, shipping first name, shipping last name, shipping company, shipping phone, shipping address 1, shipping address 2, shipping postcode, shipping city, shipping state, shipping country.”

The types of data are those included in the header of the downloaded Excel file [Datos_***FORO.1]. HO continues to inform that there are no payment data or bank card data affected by the breach and that the compromised passwords are securely encrypted. The database uses encryption (...) for user passwords.

Regarding the total number of affected individuals, it indicates that there have been (...) individuals, of which there are data for 45 individuals from countries outside of Spain:

“In the file, there were data for 45 clients with cross-border residence, of which they are:

- 3 from Belgium; 5 from Germany; 4 from France; 1 from Ireland; 1 from Italy; 2 from the Netherlands; 9 from Portugal; 1 from Sweden;
- 2 from Andorra; 2 from Switzerland; 3 from the United States; 4 from Great Britain.
- 3 from Australia; 1 from Costa Rica; 1 from Puerto Rico; 1 from Guatemala; 2 from Mexico.

The foreign clients mostly belong to the European Union, specifically to Belgium, Germany, France, Ireland, Italy, the Netherlands, Portugal, and Sweden, totaling 26 clients.”

In relation to the use by third parties or the possible publication on the Internet of the personal data obtained due to the breach, HO indicates that it is not aware of any subsequent use and provides an expert report in which the Expert and the Auditor agree that there are no indications of publication on

the internet and indexing by search engines.

.-4.5-. Regarding the security of personal data processing

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/40

In its written response to the request, HO provides a screenshot (undated) of the Risk Analysis regarding the processing activity that suffered the breach, which includes the lifecycle of the affected data and identifies the following risks:

.- 7.2.1 Risks Associated with the Legitimacy of the Processing

.- 7.2.2 Risks Associated with Transfers of Personal Data

.- 7.2.3 Risks Associated with Non-Transparency of the Processing

.- 7.2.4 Risks Associated with Data Security

.- 7.2.5 Risks Associated with Non-Compliance with the Principle of Minimization and Lawfulness

.- 7.2.6 Risks Associated with the Provision of Services

(...) analyzes the identified risk factors and calculates the inherent risk using the formula: $RISK = PROBABILITY \times IMPACT$, resulting in:

.- 7.2.1 R.A. Legitimacy of the Processing: Medium

.- 7.2.2 R.A. Transfers of Personal Data: Medium

.- 7.2.3 R.A. Non-Transparency of the Processing: Low

.- 7.2.4 R.A. Data Security: Medium

.- 7.2.5 R.A. Non-Compliance with the Principle of Minimization and Lawfulness: Low

.- 7.2.6 R.A. Provision of Services: High

“As seen in the risk assessment, we consider point 6, the risk associated with the PROVISION OF SERVICES, at that time as HIGH. At that time, as measures to minimize it, and not considering the company that managed the website at that time as a DATA PROCESSOR, NOR SUB-PROCESSOR, no additional contract was signed other than the one they had issued for performing tasks on the website. As a small company, we do not have sufficient knowledge to know if a technician or an IT company during a migration could have left a file with that data. This fact, of which we became aware in your first request, and adding other things that were breached by this previous entity, led us to decide to change IT companies as we provided in the contracts with the entity ***CONSULTORA.1.” When requested for a copy of the Impact Assessments of the processing where the security breach of personal data occurred, HO responds:

“It was not considered at the time to carry out an Impact Assessment, since the data requested on our website are not data that in this processing could give rise (in principle) to any of the exposures provided in the Regulation, in its recital 75.

It is true that it is a way to demonstrate that the processing and the risk have been analyzed, and to leave evidence so that, if what has happened to us occurs, with the Impact Assessment Report, at this moment we could have complied with the Agency by presenting it. But at the moment this happened, I reiterate, our company was not aware of the facts. Since, as we acknowledged in our previous writing, unfortunately, we had to wait for your writing to become aware of these facts.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/40

Regarding the reason why the implemented security measures did not prevent the security incident, HO indicates:

“We always understood that the IT company should have fulfilled its duties securely. Under no circumstances did it cross our minds that what happened to us could occur; as a small company, we never imagined this could happen to us.

As we indicated earlier, other factors led us to distrust, and combined with this fact, it now makes us view this aspect under a microscopic lens, because it evidently cannot happen again, not for legal compliance reasons (which we must adhere to), but because customers are our business.”

In its written response to the request, HO continues to explain the protocols it has implemented when a security breach is detected, specifying that “When a new employee joins our entity, at this moment and from the knowledge of these facts, a ‘Welcome Document’ is provided, which not only indicates the measures they must adopt regarding aspects related to confidentiality and the handling of data they access through their work, but also provides this documentation so they can act in certain situations (Harassment, Breaches, Incidents, etc.).”

The responding party attaches a screenshot of the protocol related to the BREACHES.

.-4.6-. Regarding the Security Audit and the Expert Report

In its response to the transfer of the claim, HO states that it has hired the services of a professional IT expert to try to ascertain exactly what may have occurred. When requested for the report from this expert, the responding party explains: “We have hired professionals from the very beginning, first A.A.A., an expert in IT Security, who, for personal reasons, had to stop working on resolving this problem, but recommended a company that has been helping us externally, which is ***COMPANY.2 (B.B.B.) and the IT Security expert C.C.C., who advise us on matters we do not know, and provide us with more security in being able to control everything that is done on our website and also count on them for the future website. In addition to helping us with this matter.”

HO provides the document “Security Audit” conducted by ***COMPANY.2, which includes the expert report from the National Association of Appraisers and Judicial IT Experts – ANTPJI.

The purpose of the technical Audit is to examine the information security of the website ***STORE.1 and report on the aspects indicated by the AEPD in its information request. The methodology is divided into three sections: report on where the security breach may have occurred, audit of the current IT system, and resolution of the points raised by the AEPD.

“PART I. REPORT ON WHERE THE SECURITY BREACH MAY HAVE OCCURRED.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/40

For this purpose, the auditors will be provided with the following data produced during the period from December 1, 2021, to January 31, 2022:

1. Copy of the access logs to the old website and user activity report
2. Copy of the access logs to the new website and user activity report.
3. Backups of the new and old website.
4. Correspondence between the management and the IT department of DISEÑOS HERMANAS ORTIZ CAÑÓN (***STORE.1) and the data processors that hosted the website.
5. Copy of the contracts with the data processors and the hosting service.

[...]

CONCLUSIONS

D. B.B.B. concludes that:

“During the Audit, no evidence could be obtained on how the customer file from ***STORE.1 was extracted despite having searched within the company’s IT system.

Furthermore, neither C.C.C. nor B.B.B. have been able to find the compromised file on the Dark Web or on the Internet.

We cannot establish how the leak occurred, with the explanation given by the company being plausible.”

PART II. AUDIT OF THE CURRENT IT SYSTEM.

All plugins are from reputable companies such as (...).

[...]

CONCLUSION:

Currently, the website ***STORE.1 uses WordPress technology in the recommended manner, with minimization of plugins and trusted sources, access control, and automatic updates. However, internet security is not absolute nor guaranteed.

[...]

PART III. RESOLUTION OF THE AEPD POINTS

In this section of the document [Resp#1_Doc#3], the information that has been explained throughout this report is collected. They reiterate the conclusion reached:

“During the Audit, no evidence could be obtained on how the customer file from ***STORE.1 was extracted despite having searched within the company’s IT system. Furthermore, neither D. C.C.C. nor B.B.B. have been able to find the compromised file on the Dark Web or on the Internet.

We cannot establish how the leak occurred, with the explanation given by the company of a possible oversight in changing the information system of the website being plausible.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/40

D. B.B.B., signing this Opinion, declares that he is qualified as an Expert in Computer Law and holds the title and certification of Lead Auditor from Aenor in ISO 27001.”

The reports consider January 2022 as the date of the security breach and conclude that they cannot establish how the leak occurred.

FIFTH: According to the report collected from the AXESOR tool, the entity HO has a turnover of (...) euros in the year 2023.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

II

Procedure

Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringements committed, a sanctioning procedure is initiated.

The procedure shall have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file of actions will be archived, in accordance with the provisions of Article 64 of the LOPDGDD.

If no allegations are made against this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/40

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since HO carries out, among other processes, the collection and storage of personal data of individuals, for the purpose of managing the data entered by its clients in the data collection forms on the website, as well as for managing purchases made by those clients and the delivery of orders.

To that end, it processes data such as name, surname, postal address, email address, phone number, username and password of accounts, and billing data.

HO carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

IV

Obligation Breached. Integrity and Confidentiality

Letter f) of Article 5.1 of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).”

In this case, there is evidence in the file of the publication in the forum ***FORO.1, dated June 24, 2023, referring to a publication on ***WEBSITE dated November 28, 2022, indicating that in January 2022 the online clothing store ***STORE.1 suffered a personal data breach affecting (...) clients.

Once the file [Data_***FORO.1] was downloaded, the data contained in the Excel file of the downloaded archive was analyzed. The data contained in the Excel includes:

- Name and surname.
- Postal and email address.
- User data and account password (encrypted).
- Billing data: Name, surname, postal address, and phone number.

It is verified that the Excel file contains a total of 20,570 entries, of which two rows contain the information of the claiming party, specifically rows: 8497 and 17571.

Furthermore, according to the actions taken by the inspection and the statements of the responding party, the following is recorded in the procedure:

- The personal data breach would have occurred, as declared by the responding party in its notification to the AEPD, in “November 2022.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/40

- It has been verified that the data was published on various Internet sites on dates in November 2022 and June 2023.

- The notification to the accused party of the claim was made on 27/10/2023, that is, practically one year later.

- In its response to said notification, HO states that it was not aware that the breach had occurred until receiving the claim through the AEPD. Consequently, there are indications that the data could have been accessible for a period of one year before the data controller became aware of the loss of confidentiality. Additionally, regarding the aforementioned loss of confidentiality of the leaked data, the report of the preliminary investigation actions reflects that, with the exception of passwords and billing data, the data was not securely encrypted, anonymized, or protected in such a way that it would be unintelligible to anyone who may have had access. Therefore, in accordance with the evidence currently available in this initiation agreement of sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to HO, for violation of the previously transcribed article.

V

Qualification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of

prescription

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following articles, which will be sanctioned, according to paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and will prescribe in three years, particularly the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/40

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

VI

Proposal for sanction for the violation of Article 5.1.f) GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are effective, proportionate, and dissuasive in each individual case.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as

financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD provides:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/40

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The ongoing nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In the present case, considering the severity of the possible infringement, especially taking into account the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the turnover of HO is considered, amounting to (...) euros in the year 2023.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions. Prior to this, it is estimated that the following circumstances are present:

The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2, letter a), of the GDPR).

Firstly, as stated by the party being claimed, the personal data of a total of (...) records, corresponding to their clients, have been affected. Furthermore, the risks of the exposure of such data would have increased considering that almost a year had passed from the occurrence of the breach until the controller became aware of it, which prevented them from taking the necessary measures to avoid its recurrence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/40

Furthermore, the connection of the infringer's activity with the processing of personal data is considered a factor for aggravation (Article 76.2, letter b), of the LOPDGDD). The data controller is a company dedicated to e-commerce through the website ***TIENDA.1 and has a large number of clients, in light of the number of affected individuals (...)

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD regarding the infringement committed by violating the provisions of Article 5.1.f) of the

GDPR allows for an initial administrative fine of 20,000.00 euros to be set.

VII

Unfulfilled obligation. Security of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

Article 32 does not establish static security measures, but it is up to controllers and processors to determine those security measures that are appropriate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/40

necessary to guarantee the confidentiality, integrity, and availability of personal data; therefore, the same data processing may involve different security measures depending on the specific circumstances in which such data processing takes place.

In accordance with these provisions, Recital 75 of the GDPR states:

The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from data processing that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data regarding sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to performance at work, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects. (the underlining is ours)

Furthermore, Recital 83 of the GDPR states:

In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may particularly cause physical, material, or immaterial harm. (the underlining is ours) Data security requires the implementation of appropriate technical or organizational measures in the processing of personal data to protect such data against unauthorized or unlawful access, use, modification, dissemination, loss, destruction, or accidental damage. In this regard, security measures are key when it comes to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/40

to guarantee the fundamental right to data protection. The existence of the fundamental right to the protection of personal data is not possible if the confidentiality, integrity, and availability of such data cannot be guaranteed. It should not be forgotten that, in accordance with Article 32.1 of the aforementioned GDPR, the technical and organizational measures to be applied to ensure an appropriate level of security relative to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons.

Therefore, HO, when assessing risks and determining the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk for the rights and freedoms of natural persons in the data processing it carries out as the data controller, is obliged to take into account the specific activity that constitutes its business, which involves continuously and on a large scale processing personal data (numerous data to be collected, processed, stored...); the type of data processed (identifying, contact, bank account data, etc.); the context (existence of web applications on the internet (i.e., in a non-isolated environment, which entails risks arising from the very interconnectivity that the network implies, which must be addressed in a specialized manner; existence of a common database shared by several companies with requirements for physical or logical separation).

Therefore, due to the activity it engages in, the respondent is obliged to carry out a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its activity for the rights and freedoms of individuals.

In this case, in response to the prior investigative action, HO provided the document "Measures Applied in the Creation of the Initial Website," which is an excerpt of the information provided on the page of (...) and the document "Certificate Issued by ***CONSULTORA.1 of the Current Security Measures Implemented in the eCommerce and on the Server and of the Additional Security Measures to be Implemented," which specifies the security measures implemented at the time of the report's issuance (November 2023) and others that are recommended for implementation.

According to HO, its hypothesis regarding the reason for the breach could be the installation of a plug-in on the website to export the order and user history from its previous website to migrate it to the current one, where the file subject to the breach would be hosted, such that, during the migration work, someone could have accessed that file.

In any case, on the date the breach occurred, security measures such as the following would not have been implemented:

- Implementing the AWS Trusted Advisor solution or similar in the AWS cloud infrastructure.
- Using hashing and encryption techniques to securely store passwords.
- Conducting regular security tests to identify and address potential vulnerabilities in the eCommerce.

- Implementing two-factor authentication.

Therefore, in accordance with the evidence available at this time regarding the initiation of sanctioning proceedings, it is considered that the known facts could constitute an infringement, attributable to HO, for violation of the previously transcribed article.

VIII

Qualification of the infringement of Article 32 of the GDPR and qualification for the purposes of prescription

Article 83.4 of the GDPR classifies the violation of the following articles as an administrative infringement, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43."

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 73 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679."

IX

Proposal for sanction for violation of Article 32 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/40

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the

controller or processor in relation to the same matter, the compliance with such measures;
j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/40

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) To have, when not mandatory, a data protection officer.

h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

In the present case, considering the seriousness of the possible infringement, particularly taking into account the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and deterrent, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the turnover of HO, amounting to (...) euros in the year 2023, is considered as a preliminary factor.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is deemed appropriate to scale the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions.

As a preliminary matter, the following circumstances are deemed to exist:

Firstly, the existence of negligence could be considered, to the extent that basic measures such as encryption or two-factor authentication had not been adopted at the time the breach occurred.

Secondly, the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the data processing operation in question, as well as the number of affected parties and the level of damages they have suffered (Article 83.2, letter a), of the GDPR). In this specific case, personal data of (...) records corresponding to HO's clients would have been exposed, consisting of their first and last names, postal and email addresses, user data and password for their account (encrypted), and billing data (name, last names, postal address, and phone number). Such data would have been exposed for more than a year.

The link of the infringer's activity with the processing of personal data is considered an aggravating factor in the scaling of the sanction (Article 76.2, letter b), of the LOPDGDD). The data controller is a company dedicated to e-commerce through the website ***TIENDA.1 and has a large number of clients, in light of the number of affected parties (...).

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/40

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, initially allows for the imposition of an administrative fine of €5,000.00.

X

Unfulfilled obligation. Communication of a personal data security breach to the data subject
The communication of a personal data security breach to the data subject is regulated in Article 34 of the GDPR, which states:

"1. When a personal data security breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate the breach to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this article shall describe in clear and plain language the nature of the personal data security breach and shall at a minimum contain the information and measures referred to in Article 33, paragraph 3, letters b), c), and d).

3. The communication to the data subject referred to in paragraph 1 shall not be necessary if any of the following conditions are met:

a) the data controller has implemented appropriate technical and organizational protection measures, and those measures have been applied to the personal data affected by the personal data security breach, in particular those that render the personal data unintelligible to any person not authorized to access it, such as encryption;

b) the data controller has taken subsequent measures that ensure that the high risk to the rights and freedoms of the data subject referred to in paragraph 1 is no longer likely to materialize;

c) it would involve a disproportionate effort. In this case, a public communication or a similar measure shall be adopted to inform the data subjects in an equally effective manner.

4. When the data controller has not yet communicated the personal data security breach to the data subject, the supervisory authority, after considering the likelihood that such a breach poses a high risk, may require the data controller to do so or may decide that one of the conditions mentioned in paragraph 3 is met."

In the present case, the knowledge of a personal data security breach would have occurred, according to the claimant, due to the transfer of the complaint to HO by this Agency. This transfer was notified on 21/10/2023, through the DEHÚ service, with HO accessing the notification on 31/10/2023. However, the notification to the data subjects did not occur until 19/12/2023, violating the provisions of Article 34.1 of the GDPR, which requires that such notification be made "without undue delay."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

27/40

On the other hand, it is understood that the circumstances indicated in Article 34.3 would not apply in this case, given that the knowledge of the breach occurred more than a year after it took place, having been exposed at least since January 2022, and the data were not encrypted or similarly protected by other technical means.

Therefore, in accordance with the evidence available at this time regarding the initiation of sanctioning proceedings, it is considered that the known facts could constitute an infringement attributable to HO for violating the previously transcribed article.

XI

Classification of the infringement of Article 34 of the GDPR and qualification for the purposes of prescription

Article 83.4 of the GDPR classifies the violation of the following articles as an administrative

infringement, which shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 74 of the LOPDGDD establishes the following:

"Minor infringements are considered and shall prescribe after one year for the remaining formal infringements of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU)

2016/679 and, in particular, the following:

ñ) The failure to communicate to the affected party a breach of personal data security that poses a high risk to the rights and freedoms of the affected parties, as required by Article 34 of Regulation (EU) 2016/679, unless the provisions of Article 73 s) of this organic law apply."

XII

Proposal for a sanction for violation of Article 34 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/40

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the

aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In the present case, considering the severity of the possible infringement, especially regarding the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the turnover of HO is considered, amounting to (...) euros in the year 2023.

In this case, the initial assessment regarding the infringement committed by violating the provisions of Article 34 of the GDPR allows for an initial administrative fine of 1,000.00 euros to be set.

XIII

Unfulfilled obligation. Processor

The provisions regarding the processor are set out in Article 28 of the GDPR, which stipulates the following:

"1. When processing is to be carried out on behalf of a controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, so that the processing will be in compliance with the requirements of this Regulation and will ensure the protection of the rights of the data subject.

(...)

3. The processing by the processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and establishes the subject matter, duration, nature, and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller.

Such contract or legal act shall stipulate, in particular, that the processor:

- a) shall process the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organization, unless required to do so by Union law or the Member States.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/40

members that apply to the processor; in such case, the processor shall inform the controller of that legal requirement prior to processing, unless such law prohibits it for important reasons of public interest;

- b) shall ensure that the persons authorized to process personal data have committed themselves to respect confidentiality or are subject to a legal obligation of confidentiality;
- c) shall take all necessary measures in accordance with Article 32;
- d) shall respect the conditions set out in paragraphs 2 and 4 for engaging another processor;
- e) shall assist the controller, taking into account the nature of the processing, through appropriate technical and organizational measures, insofar as possible, so that the controller can comply with its

obligation to respond to requests concerning the exercise of the rights of the data subjects established in Chapter III;

f) shall help the controller ensure compliance with the obligations set out in Articles 32 to 36, taking into account the nature of the processing and the information available to the processor;

g) at the choice of the controller, shall delete or return all personal data once the provision of processing services has ended, and shall delete existing copies unless the retention of personal data is required by Union or Member State law;

h) shall make available to the controller all information necessary to demonstrate compliance with the obligations set out in this article, as well as to enable and contribute to audits, including inspections, by the controller or another auditor authorized by the controller.

In relation to the provisions of letter h) of the first paragraph, the processor shall immediately inform the controller if, in its opinion, an instruction infringes this Regulation or other provisions on data protection of the Union or the Member States.

(...)

9. The contract or other legal act referred to in paragraphs 3 and 4 shall be in writing, including in electronic format.

In this case, in its response to the request in the Preliminary Investigation Act, dated 24/04/2024, HO states the following regarding this point:

"In the case of the company that maintains the website, this company began a project in DECEMBER 2021, which was when the first contract was signed, until the PRESENT. ***CONSULTORA.1 has been working and helping us try to comply with everything that involves our website. They do not process customer data in their work on the website. For this reason, they have not been considered as processors, nor as sub-processors."

However, according to what HO has stated regarding its hypothesis about the reason why the breach may have occurred, the company ***CONSULTORA.1, for the migration of the website, receives a file with personal data of the company's customers with the aim of transferring them to the new website. In this sense, it carries out data processing in accordance with the criteria of Article 4.2 of the GDPR, which defines it as follows:

2) "processing": any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, alignment, combination, restriction, erasure or destruction.

Such processing is carried out on behalf of the controller, HO, and can therefore be considered a processor, in accordance with Article 4.8 of the GDPR, which defines it as follows:

8) "processor": the natural or legal person, public authority, service, or other body that processes personal data on behalf of the controller.

Therefore, in accordance with the evidence currently available in the initiation of sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to HO, for violation of the previously transcribed article, to the extent that there was no contract governing such processing.

XIV

Qualification of the infringement of Article 28 of the GDPR and qualification for the purposes of limitation

Article 83.4 of the GDPR classifies as an administrative infringement the violation of the following articles, which shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

b) the obligations of certification bodies under Articles 42 and 43;

c) the obligations of the supervisory authority under Article 41, paragraph 4."

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as

well as those that are contrary to this organic law, constitute infringements.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/40

For the sole purposes of the statute of limitations, Article 73 of the LOPDGDD establishes the following:

"In accordance with Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years, particularly the following:

k) Entrusting the processing of data to a third party without the prior formalization of a contract or other written legal act containing the requirements set forth in Article 28.3 of Regulation (EU) 2016/679."

XV

Proposal for sanction for violation of Article 28 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.

- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In the present case, considering the severity of the possible infringement, particularly the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the turnover of HO is considered, amounting to (...) euros in the year 2023.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions.

Prior to this, it is estimated that the following circumstances are present:

The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/40

number of affected parties and the level of damages they have suffered (Article 83.2, letter a), of the GDPR).

First, it should be considered regarding the severity of the infringement that the absence of a contract with the data processor, as established by Article 28 of the GDPR, results in a lack of instructions from HO as the data controller.

Furthermore, the connection of the infringer's activity with the processing of personal data (Article 76.2, letter b), of the LOPDGDD) is considered an aggravating factor. The data controller is a company dedicated to e-commerce through the website ***TIENDA.1 and has a large number of clients, in light of the number of affected parties (...)

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 28 of the GDPR, allows for an initial administrative fine of 5,000.00 euros.

XVI

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to comply with personal data protection legislation, in this case, Articles 5.1 f), 32, 33, 34, and 28 of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, which states that each supervisory authority may "order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame..."

Thus, the responsible entity may be required to align its actions with personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the presumed infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures must be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments

for implementing them correspond to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

In this case, regardless of the above, in accordance with the evidence available at this moment regarding the initiation of the sanctioning procedure, the resolution adopted may require HO to adopt the following measures within three months from the date of effectiveness of the resolution concluding this procedure:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

35/40

- Demonstrate the adoption of the necessary measures to ensure compliance with the provisions of Article 5.1 f) of the GDPR, in such a way that it guarantees adequate security in the processing of personal data, through appropriate means, such as the use of encryption techniques for data storage.
- Demonstrate the adoption of the necessary measures to ensure compliance with the provisions of Article 32 of the GDPR, in such a way that an adequate level of security is guaranteed according to the risk, through appropriate means, such as the use of hashing or encryption techniques for data storage, as well as conducting security tests.

- Demonstrate the execution of the corresponding data processing agreement with

***CONSULTORA.1 or the company that is at that moment performing tasks that involve operations of personal data processing, such as those that were, at the time, the migration of the website.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, according to the provisions of Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of this sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, and such conduct may lead to the initiation of a further administrative sanctioning procedure.

Furthermore, it is reminded that neither the acknowledgment of the infringement committed nor, if applicable, the voluntary payment of the proposed amounts, exempts the obligation to adopt the necessary measures to cease the conduct or correct the effects of the infringement committed and to demonstrate to this AEPD compliance with that obligation.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L., with NIF B39843487, for the presumed infringement of the following articles of the GDPR:

- Article 5.1 f), classified in Article 83.5
- Article 32, classified in Article 83.4
- Article 34, classified in Article 83.4
- Article 28, classified in Article 83.4

SECOND: TO APPOINT D.D.D. as the instructor and E.E.E. as the secretary, indicating that they may be recused, if applicable, in accordance with the provisions of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

36/40

Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, the claim filed by the claiming party and its documentation, as well as the documents obtained and generated by the General Sub-Directorate for Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of THIRTY-ONE THOUSAND EUROS (31,000.00 euros), without prejudice to what results from the instruction, corresponding to the following infractions:

- Article 5.1 f), administrative fine of TWENTY THOUSAND EUROS (20,000.00 euros)
- Article 32, administrative fine of FIVE THOUSAND EUROS (5,000.00 euros)
- Article 34, administrative fine of ONE THOUSAND EUROS (1,000.00 euros)
- Article 28, administrative fine of FIVE THOUSAND EUROS (5,000.00 euros)

FIFTH: NOTIFY this agreement to DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L., with NIF B39843487, granting a hearing period of ten working days for it to formulate allegations and present the evidence it deems appropriate. In its written allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 24,800.00 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 24,800.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the sanction would be set at 18,600.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the express withdrawal or renunciation of any action or administrative appeal against the sanction.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/40

For these purposes, in the event of opting for either of them, it must send to the General Sub-Directorate for Data Inspection an express communication of the withdrawal or renunciation of any action or administrative appeal against the sanction indicating which of the two reductions it is opting for or if it is for both.

In the event that it chooses to proceed with the voluntary payment of any of the amounts indicated above (24,800.00 euros or 18,600.00 euros), it must do so by depositing it into account no. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is adhering.

Likewise, it must send the proof of payment to the General Sub-Directorate for Inspection along with the express communication of the withdrawal or renunciation of any action or administrative appeal against the sanction to continue with the procedure in accordance with the amount deposited.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

1479-141024

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On November 28, 2024, HO proceeded to pay the sanction in the amount of 18,600.00 euros making use of the two reductions provided for in the initiation agreement transcribed above, which implies the acknowledgment of responsibility in relation to the facts referred to in the initiation agreement and its legal qualification.

THIRD: HO has expressly renounced any action or administrative appeal against the sanction.

FOURTH: In the initiation agreement transcribed above, it was indicated that, if the infraction were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/40

present Regulation, when appropriate, in a specific manner and within a specified timeframe...”.

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the initiation agreement is warranted.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading “Termination in sanctioning procedures” provides as follows:

“1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when a pecuniary sanction can be imposed alongside a non-pecuniary sanction but the latter has been justified as inappropriate, voluntary payment by the alleged responsible party at any time prior to the resolution will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned on the withdrawal or renunciation of any action or administrative appeal against the sanction.

The percentage of reduction provided in this section may be increased by regulation.”

III

Voluntary payment and acknowledgment of responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the initiation agreement notified included information about the possibility of acknowledging responsibility and making voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be set at 18,600.00 euros, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the notification of the aforementioned initiation agreement, HO has proceeded to acknowledge responsibility and make voluntary payment of the sanction, availing itself of the two reductions provided and expressly waiving any action or administrative appeal.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution.

The sum of the aforementioned amounts results in a total of 31,000.00 euros.

After DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L. has made prompt payment and acknowledged responsibility, a reduction of 40% of the total mentioned is applied, resulting in a final amount of 18,600.00 euros.

SECOND: TO DECLARE the termination of procedure EXP202315109, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L. to notify the Agency within 3 months from the date this resolution becomes final and enforceable, regarding the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/40

FOURTH: NOTIFY this resolution to DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility on the withdrawal or renunciation of any action or administrative appeal by this authority, the express renunciation manifested by DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L. is accepted. Consequently, the filing of an optional appeal for reconsideration against this resolution is not admissible, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is admissible due to the express renunciation, this resolution will be final and fully enforceable from the moment of its notification.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the final resolution may be provisionally suspended in the administrative process if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency

does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

1259-180225

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es